ClaimGuard AI: Privacy and Security Note

Submission document: threat model, access control, least privilege and auditability, with everything else we built that bears on privacy and security.

Team project for the CSTAM-VELODOC challenge (mentor: Dr. Wael Hilali). Note date: 2026-10-19. Branch `rust-rewrite`. The companion submission is the *Test Evaluation Report* (`docs/56`): it holds the detection metrics, F1, false-positive rate, latency and the experiments. **This note holds the security and privacy material and does not repeat those numbers.**

Scope and honesty. All data in this repository is synthetic: no real patient, member, provider or payer exists in it. Having no real personal data is not a compliance assessment for a future healthcare product, and nothing here is legal advice (the law binds the organisation that runs the system, not the software). Every "built" below has a test, a script or a file you can run; every "not built" is listed in section 12. The system exists twice: the Python reference (Phase 1) and the Rust rebuild that the server and the desktop app run. This note describes the **Rust build** unless it says otherwise, and uses the Python-era audit (`docs/20`, `docs/32`) where it still applies.

---

1. The answer on one page

The note asks for	What we have	Section
Threat model	Assets, adversaries, trust boundaries and 25 threats, each with the control that answers it, the evidence, and what remains. Includes the AI-specific threats (OWASP LLM Top 10) and the document-upload path.	2
Access control	Badge + password + authenticator code; server-side sessions that can be revoked; cross-site and anti-forgery checks; four clearance levels with per-permission flags enforced on the server, never only by hiding a button; separation of duties (the person who runs the queue cannot decide claims; nobody countersigns their own decision); two-person approval for the most dangerous administrator actions and for payer-rule changes.	4
Least privilege	For people: four levels, masked identifiers by default, unmasking rationed to 60 claims an hour with a written reason. For software: non-root, read-only containers with all capabilities dropped, a reader with no network, a private network for the database, and the signing key held by the worker alone. For data: the AI never sees a claim value.	5
Auditability	Hash-chained, encrypted audit logs; a keyed anchor; a second append-only copy that is checked against the live log; an optional outside timestamp; an Ed25519-signed Merkle ledger with single-event proofs; AI requests written **before** the model is called; every decision attributed to the signed-in person; corrections as new versions, never edits.	6

Headline evidence (all re-runnable, section 9): **116-check black-box penetration test, all pass**; **400,000 fuzzed requests, 0 server errors, 0 leaks**; **75 deliberate breakages of the security rules, all caught**; a **50-check attack on the deployed stack** that found four real problems (fixed); a red team on a real local model that found and fixed a real weakness in the AI guard; claim data, names and audit logs encrypted at rest; an encrypted backup restored end to end.

Three things the note will not claim: it has **not been run on the target server**, it has **not been tested by an outside party**, and **erasure on request, subject-access export and a retention period are designed but not built** (section 12).

---

2. Threat model

2.1 Assets

Asset	Why it matters
Claim data and identifiers (patient, member, provider, diagnoses, services)	personal and health data, which Middle East data-protection laws treat as sensitive
The uploaded document itself (PDF, scan, photo)	may hold anything, including a hostile payload
The verdicts and the reviewer decisions	a wrong or forged verdict becomes a wrong payment decision
The audit logs and the ledger	the evidence of who did what; their value is that nobody can quietly edit them
Credentials: passwords, authenticator seeds, session tokens	the key to everything above
Secrets: the data key, the Fernet key, the ledger signing seed, the audit anchor key, the reader token, the sidecar token	losing or leaking one weakens a whole class of protection
Availability of the queue	claims waiting on a person must not be lost or blocked

2.2 Who might attack, and what we assume about them

Adversary	Capability assumed
Outsider on the network	can reach the proxy; no credentials
A submitter (provider or staff member who files a claim)	controls every field of a claim and every uploaded document, so can plant instructions, markup or lookalike characters in them
A curious or careless reviewer	has a valid account at levels 1 to 3; may browse, copy or mistype
A malicious insider reviewer	tries to exceed their level, decide their own work, or copy identifiers out in bulk
A malicious or compromised administrator	has level 4; could try to alter users, rules or logs
Someone with a stolen session or a guessed badge number	can try to act as, or lock out, another person
Someone with file or database access	could edit, truncate or read the stores and logs
The model itself	treated as untrusted: it may obey injected text or write something misleading
The software supply chain	a vulnerable or tampered dependency or image

Out of scope, and said so: an attacker who controls the host operating system, the Docker daemon, and every key at once; a distributed denial of service; physical access; side channels below the HTTP layer.

2.3 Trust boundaries and data flow

1. **Internet to proxy** (nginx or Caddy; TLS ends here). Only the proxy publishes a port.

2. **Proxy to API** (private network). The API is the only component that reads the stores for people.
3. **API to database and cache** (MongoDB, Redis on an `internal` network with no route to the internet, each demanding a password).
4. **API to the document reader** (bearer token, private network, no outbound route). The reader returns a draft; it never writes a claim.
5. **API to the embedding sidecar** (bearer token, private network). The sidecar sees the text of rulebook passages and a reviewer's question, never a claim.
6. **API to the local language model** (vLLM or Ollama on the hospital's own machine). The model receives a template with placeholders; claim values are filled in afterwards.
7. **Worker to the ledger and the audit mirror.** The worker is the only holder of the signing seed and the only writer of the mirror volume.

Nothing in the deployed system calls out to a third party. The one optional outside call is an RFC 3161 time-stamp request, which carries a hash of the log head and no data.

2.4 Threats, controls, evidence and what remains

#	Threat	Control	Evidence	Remains
T1	Guessing or stealing a password	bcrypt hashing (cost 12 in production); a second factor (authenticator code, each code usable once); per-(badge, client) and per-address throttles stored in the database	pen test (authentication, 6 checks); `cg-access` tests	a user who loses both factors needs an administrator and a second administrator's approval
T2	Locking the owner out (denial through the lock-out itself)	the lock keeps out **only clients the person has never signed in from**; the owner's usual client is unaffected; a successful sign-in clears the lock	5 tests; 6 mutants all caught (docs/39 6.1)	an attacker can still block a *new* device for 15 minutes
T3	Learning which badges exist (enumeration, timing)	identical bodies for known and unknown badges; every refusal does the same work: eight kinds of refusal timed within 3% (80.3 to 82.6 ms)	`cargo test -p cg-access --test timing`; pen test	network timing across a real network not measured
T4	Session theft and forgery	signed tokens (algorithm confusion, `none`, five weak keys, swapped payload, truncation all refused); server-side revocation; `SameSite=Strict` cookies; the payload holds ids and times only	pen test (session tokens, 2)	a stolen *live* session works until revoked or expired
T5	Cross-site request forgery	an anti-forgery token on every state change; **and** an independent check that refuses (403 `cross_site`) any state-changing request the browser says is cross-site, has a `null`/empty/mismatched `Origin` (including `http://host:8443.evil.example`)	pen test (CSRF 4 checks, plus the third-round checks)	
T6	A reviewer exceeding their level	permissions re-read from the user store at the moment of each action, so a demotion is immediate; every role tested against 12 reads and 3 writes; mass assignment and self-promotion refused	pen test (authorization, 11 checks); mutation tests	
T7	Reading a claim that is not yours	a claim leased to someone else answers 404 exactly as a missing one does (no existence leak); a decision is bound to a lease the person holds	pen test	

#	Threat	Control	Evidence	Remains
T8	Deciding your own work, or one person doing a two-person job	the reviewer on a decision is always the signed-in person (never a client field); the first signer of a high-severity finding can never be the second; level 4 holds no decision right; a conflict-of-interest list bars a reviewer from a named patient	pen test (business logic, 9 checks); mutants	two accounts controlled by one person defeat any two-person rule; the log records who did what
T9	An administrator misusing their power	the most dangerous actions (replacing someone's authenticator, creating or changing an administrator) and every payer-rule change need a **different** administrator's approval with a **fresh code of their own**; a request expires in a day; a wrong code is not counted as approval	8 service tests, 1 API test, 18 mutants; 116-check pen test	a **lone** administrator acts alone (nobody could approve); each such action is logged
T10	Bulk copying of identifiers by an insider	identifiers are masked by default; unmasking needs a separate permission and a written reason, is logged, and is limited to **60 claims per person per hour** (the count lives in the database, so it holds across processes); the reason may not itself contain the identifier	pen test privacy checks; mutants	a patient can still be recognised from context in a claim's other fields
T11	Rewriting history	hash-chained logs; a keyed (HMAC) anchor; a second append-only copy that refuses to follow a live log that was edited, cut or replaced; an optional RFC 3161 timestamp; a signed Merkle ledger	section 6; `audit_guard_demo.py`	tamper-**evident**, not immutable (section 6.4)
T12	Reading data from the disk or a stolen backup	claim, results, explanations and every decision (with its reason) are encrypted fields, each bound to its claim, version and field name; people's names and both audit logs are encrypted; backups are one AES-256 file	raw-storage tests; backup test (23 checks)	user records other than the name, and the keys themselves, depend on host controls
T13	A hostile document (malware, polyglot, PDF with active content)	a gate before anything reads the file: type read from the bytes (PDF, PNG, JPEG only), size and pixel caps, PDFs with JavaScript, launch actions, embedded files or encryption refused, polyglots and files with an executable appended refused; then an isolated reader container with no network, read-only, capabilities dropped, memory and process limited	9 API flow tests, 18 black-box checks on the reader (hostile PDFs, bad types, oversize), 17 browser checks	hidden text in a PDF's text layer is read like visible text (a person always compares the page)
T14	A document or claim that talks to the system (prompt injection)	claim text is data: extraction is pattern matching for documents; the model only adds words and can never set a status, a rule id, a citation or the review flag	section 7	misleading-but-schema-valid wording is possible; a person reviews every claim
T15	The model writing something false or an approval	schema, citation, grounding (allow-list), invisible-character, foreign-script and garbled-text guards; a failed reply is replaced by the engine's own sentence	section 7; 4,212 live calls in the experiments changed no finding	non-English Latin text and Base64 pass the text guards (cannot change any status)
T16	Forged rule facts (a value that imitates a rule tag)	claim data is percent-encoded before it enters a fact	`RuleFactInjection` test over all tags × all string fields	

#	Threat	Control	Evidence	Remains
T17	A lookalike identifier (Arabic letters, Arabic-Indic digits, invisible or bidirectional characters inside an id)	the Arabic localization step refuses them inside identifiers, refuses Hijri and ambiguous dates, unknown field names, duplicate fields; English input is byte-identical; every change is recorded and the original claim kept	16 unit tests; Arabic twins give identical results for all 15 rules	native-speaker review of the Arabic wording not done
T18	A poisoned batch slipping through automatically	a random 5% audit sample of every batch; one wrong sampled green claim quarantines the whole batch; automatic clearing and automatic requests are **off by default** and worded "pre-validation clear", never approval	docs/53; docs/50	the audit-sample thresholds are policy choices awaiting the mentor
T19	Poisoning the reviewer-feedback signal	the confidence-routing and learning loops that could be poisoned are **archived and not wired**; the read-only workload report changes no routing	docs/48 (poisoning study); docs/49	an adversary who decides 40% to 80% of a rule's decisions defeats the archived design's protections
T20	Flooding the server (one machine)	header timeout 10 s, 16 KB header cap, 2,048 connections, 5-minute lifetime, per-address and per-badge throttles, body caps (100 KB default, 4 MB on batch submit, 16 MB on the two import routes); nginx in front	flood test, 16 checks; nginx test, 22 checks	a distributed attack and floods below HTTP are untested
T21	A published container port bypassing the firewall	`firewall.sh` in `DOCKER-USER` and `INPUT`, plus an outside port check	15 container checks	not yet run on the target host
T22	A vulnerable or tampered dependency or image	every third-party image pinned by digest (a test fails if one is not); `cargo audit` and `pip-audit` clean or each exception recorded with its reason; a distroless runtime image with no shell	section 9	scans are snapshots
T23	Losing everything	one encrypted backup file holding both databases, both logs and the mirror; restore refuses a wrong key, a damaged file or contents that do not match their checksums	23-check destroy-and-restore test (found two bugs in its own first version)	backups are a manual procedure, not scheduled
T24	A script injected into the console	strict content-security policy (no inline script, no framing); all untrusted text rendered as text	19 checks in a real Chrome with payloads planted in 10+ fields	
T25	A message planted on the broker	each message is checked against the stored claim's hash; a forged one changes nothing; poison input dead-letters after three tries; Redis is on the private network with a password and is not published	18 broker mutants	someone with the Redis port can still fill the stream

3. Privacy: what is stored, who can read it, and what the system refuses to do

3.1 What is stored, where, and who can read it

Record	Where	Holds an identifier?	Who can read it	Protection
Claim body, rule results with their evidence, AI explanations	queue store (MongoDB `claims`)	yes, but **encrypted at rest** (each field bound to claim, version and field name)	levels 1 to 3 through the API, **masked** by default (stable pseudonyms such as `PAT-xxxx`); levels 2 and 3 may unmask one claim with a typed reason	masking at the API; encryption; database access control
Reviewer decisions and their free-text reasons	same document, and the review log	not by design; the reason is typed by a person	reviewers; level 4 sees counts only	reasons that contain the real identifier are **refused (422)** on every route; encrypted; never copied into reports
Deal documents (who was dealt what)	queue store	**no**: they keep the badges barred from a patient, not the patient	level 4	tested on a real flow
Security log, review log	JSONL, hash-chained, **one encrypted row per line**	badge numbers and claim ids, never a name	level 4 (`audit.view`)	section 6
Users: badge, password hash, authenticator seed, level, grants	MongoDB `users`	staff data	level 4	names encrypted and bound to the badge; seed encrypted; password never stored
Index to find a patient's earlier claims	MongoDB	a **keyed hash** of the patient id, not the id	the server	keyed hash
Feedback and workload reports	computed on request	no	level 4	counts and exact intervals only; no reason text, claim id or badge

3.2 Data minimisation, what changed and the check

- **The AI never sees a claim value.** The language model receives a template with `{value}` and `{line}` placeholders; the values are filled in afterwards and the grounding guard runs on the filled text.
- **The rulebook search never reads a claim.** "Ask the rulebook" retrieves a quoted passage from the 15 rules and the payer policies; the embedding sidecar sees only passage text and the reviewer's question.
- **The copilot uses no model.** Summaries and correction suggestions are built by code from the engine's findings and the claim's own values; every sentence names the rule and the claim paths it rests on.
- **Uploaded documents are not stored by the server.** The preview returns the draft to the browser; only a confirmed claim reaches the queue, with a note that names the file by its hash. The security log records the file's hash, size and outcome, never its content.
- **Logs are scanned for identifiers.** After a real decision and a real deal, the security and review logs and the dead letters contain none of the claim's real identifiers (`tests/test_data_minimization.py`, memory and MongoDB stores).
- **Feedback to rule owners** is counts and exact intervals only.

3.3 Where the data goes

Everything runs on the hospital's own servers: the API, the worker, the database, the cache and the language model (vLLM or Ollama, local). The database and the cache sit on a network with no route out. The rule engine and the AI step make no outside calls. **The Rust build refuses to use a cloud model provider** (the Python build has them, for experiments only). There are no third-party processors in the deployed system. The Python-era note listed the real risk of the cloud path (member ids in evidence reaching an outside provider): in the Rust build that path does not exist.

3.4 Middle East data-protection laws (the mentor's requirement)

The mapping against the families of obligation shared by the Saudi PDPL, the UAE Federal Decree-Law 45 of 2021, Qatar Law 13 of 2016 and others is in `docs/41`. In summary:

Obligation family	Status
Data stays in the country; limits on cross-border transfer	**Built**: everything on-premise; deployment attack checks isolation, ports and egress
Data minimisation	**Built** (masking, rationed unmasking, AI sees no values)
Purpose limitation and access control	**Built** (four levels, server-enforced)
Security safeguards	**Built** (TLS 1.2/1.3, HSTS; encryption at rest; two-factor sign-in; revocable sessions; tamper-evident audit; dual control; encrypted backups)
Accuracy and correction	**Built**: a correction is a new version checked from scratch; the old decision stays visible
Breach detection	**Built** (audit chain, mirror and timestamp alarm on any rewrite; the health panel shows it; failed sign-ins and unmask counts are logged); *notification* is a process, not software
Access, correction, deletion and objection by the person	**Not built**: no export of everything held about one person, and no erasure on request. Design: destroy the keyed index entry and the claim's sealed fields for that person (the audit log keeps claim ids only, so the deliberately uneditable log needs no rewriting)
Retention	**Not built** beyond short-lived data that expires by itself; needs the insurer's decision
Records of processing, impact assessment, data-protection officer	the documents list what is processed and why; a formal assessment and a named officer belong to the operating organisation

---

4. Access control

4.1 Authentication

- **Three things to sign in:** badge number, password, and a one-time code from any authenticator app. A used code is never accepted again, here or at sign-in.
- **Throttling designed so it cannot be used as a weapon:** five failures per (badge, client) per 15 minutes; 100 failures per address; the counters live in the database (a restart or a second process sees the same counts; addresses are stored only as keyed hashes). The lock keeps out only never-seen clients, so a stranger cannot keep the owner out of their usual device.
- **Sessions:** cookie plus anti-forgery token, `SameSite=Strict`, server-side revocation, a revoked session ends a live-update stream.

- **Refusals look alike:** unknown badge, malformed badge, locked, inactive, wrong password, wrong code, replayed code and throttled client all take the same steps and the same time (within 3%).
- **Headers and transport:** `X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`, `Cache-Control: no-store`, a content-security-policy (API and console), `Permissions-Policy`, no server banner; no CORS header is ever sent; TRACE, CONNECT and unknown verbs refused; HTTP smuggling forms (two lengths, length with chunking, NUL, folding) refused.

4.2 Authorization: the four levels

Level	Can	Cannot
1 viewer	list and view claims with masked identifiers, no notes, no action buttons	unmask, decide, audit, administer
2 reviewer	the above plus notes, unmask (audited, with a reason, rationed), decide medium-severity findings, correct and recheck	decide high-severity findings, administer
3 senior reviewer	the above plus decide high-severity findings	administer
4 administrator	users, routing settings, payer rules, import of files, audit log and its verification, queue overview, health, claim traces	**read claims, unmask, decide**

Rules that make the table real:

- **The server enforces it.** A viewer is not offered an action, and asking for it is refused and logged. Permissions are re-read at the moment of each decision, so a demotion is immediate; nothing is cached.
- **Separation of duties.** Whoever runs the system cannot approve its claims. A high-severity finding needs two different seniors. A person never countersigns their own decision. A conflict-of-interest list bars a reviewer from a named patient.
- **The decision is attributed to the session,** never to a field the client sends, and bound to a lease the person currently holds.
- **No existence leak:** a claim leased to someone else answers 404, the same as a claim that does not exist.

4.3 Two-person control

- **Dangerous administrator actions** (replacing an authenticator, creating or changing an administrator) return `202` and change **nothing** until a different administrator approves with a fresh authenticator code of their own (so a stolen session cannot approve). The requester cannot approve or reject their own request; a request is decided exactly once, atomically (four administrators approving in parallel: one wins), and expires after a day; the rules for the action are checked again at approval. It applies once two administrators are active.
- **Payer-rule changes** (price and quantity limits, allowed providers, authorization lists, required documents, submission window): validated, shown as a list of differences, need a reason and, with two administrators, a different administrator's approval with a fresh code. Each version is kept in a hash-chained history; rollback is a new version; every receipt records the table version. The 15 rules themselves are fixed code and cannot be edited from the console.
- **Corrections** never overwrite: a recheck is a new version of the claim; the original is kept as received and closed.

4.4 The permission matrix is tested, not just designed

The penetration test runs every role against 12 read routes and 3 write routes and checks the answer against the permission table, including an administrator trying to read or decide claims, mass assignment on user creation, granting an administrator right to a reviewer, deactivating the last administrator, writing a password hash, self-promotion, and deciding or verifying another reviewer's claim. The mutation test (section 9.3) breaks each rule on purpose and checks that a test fails.

---

5. Least privilege

5.1 For people

- Four levels, each with per-permission flags (docs/39 section 5). The administrator, who can change everything about *how* the system runs, cannot read a claim; the reviewer, who can read claims, cannot change a user or a rule.
- Identifiers are masked unless a person has the unmask permission **and** gives a reason **and** is under 60 unmasks an hour. A reviewer who unmasks hundreds of claims an hour is copying, not reviewing; a stolen session cannot empty the system quickly.
- Only administrators can import files; only the worker signs; only level 4 can read a batch-intake job (a level 3 user gets 403).
- The two automatic-decision options that change who looks at what (`auto_clear_green`, `bulk_confirm_skip_lower`) and automatic requests for information are **off by default** and every change to the routing configuration is logged with before and after.

5.2 For software

Component	What it can do	What it cannot
API	read and write the queue stores, verify ledger signatures with the **public** key	sign the ledger; reach the internet; hold the ledger's signing seed
Worker	sign the ledger; write the audit mirror volume (the only mounter of that volume)	answer requests from people
Document reader	read one document at a time from the API; talk to its own vision model on a private network	reach the internet, the database, or any model credentials; write a claim
Containers (API, worker, reader)	run as non-root; only `/tmp` and `/data` writable	write the root file system; hold a capability (all dropped); gain privilege (`no-new-privileges`); see a host path, the Docker socket or the host network; exceed memory, process or CPU limits
Runtime image	the program, the C library and certificates	no shell, package manager or interpreter (distroless); no secret, key or demo account file baked in
MongoDB and Redis	accept the API and the worker	be reached from the proxy, from the internet, or without a password
Embedding sidecar	embed text on request with a bearer token; model pinned at a fixed revision, runs offline (`HF_HUB_OFFLINE=1`)	see a claim; make an outbound call

Component	What it can do	What it cannot
The language model	add words to an explanation	set a status, a rule id, a citation or the review flag

The deployment attack (section 9.4) verifies the container rows by attacking the running stack.

5.3 For data

- Evidence quoted in findings is the minimum a reviewer needs; the model gets placeholders; the rulebook search never touches a claim; the live-update stream carries only `hello`, `changed` and `end` and re-reads through the ordinary permission-checked routes.
- A claim's encrypted fields are bound to their claim, version and field name, so moving one claim's evidence under another is detected and refused.
- Dismissal-reason text never reaches a report.

---

6. Auditability

6.1 What is recorded

One chain per log; every row is `{sequence, recorded_at, previous_hash, event, hash}` with `hash = SHA-256(canonical row)`.

Event	Written by	Contents
`ingestion`	system	claim id, source format, accepted or quarantined with the reason
`run_started` / `run_finished`	system	run id, SHA-256 of the input claim; rule pack hash, rule versions, tool errors
`rule_check`	system	one per rule: id, version, status, severity, affected lines, **hash of the full result**, `confidence: null`, `method: deterministic`
`ai_request`	system, **written before the model is called**	the question put to the AI, the finding's hash, the prompt version and **hash of the exact prompt**, the hash (never the text) of any untrusted note
`ai_recommendation` / `ai_failure`	system	model or template, fallback flag, latency, tokens, the explanation, `action_type: human_escalation`, `auto_correct_applied: false`
`system_decision`	system	`route_to_human_review`, `no_findings_for_review` or `quarantine_claim`; the system **cannot** record an approval or a denial
`confirm_issue` / `dismiss_with_reason` / `request_information` / `mark_corrected_for_recheck`	the signed-in person	actor, reason, original status, timestamp
`recheck_run`	system	links the prior run and the new run and both input hashes
security events	system	logins, lock-outs, unmasks, decisions, deals, approvals, refused requests, routing changes, document imports (hash, size,

Event	Written by	Contents
		outcome), what-if runs; the vocabulary is closed and a field named like a secret is refused

The write-ahead rule: if the `ai_request` cannot be written, the run aborts. The model is never called for something the log does not know about.

6.2 How tampering is made visible

Control	Status	Evidence
Hash chain; edits and reordering detected	**Built**	`tests/test_audit_log.py`, `cg audit-verify`
Head hash and count in a **keyed (HMAC) anchor**, strict check on verify	**Built**; closes the "appended forged rows" hole found in the Python-era audit	`audit_log.verify_with_anchor(strict=True)`
Second append-only copy (`audit_mirror`, every 5 minutes) on a separate volume; before copying it proves what it already holds is still byte-for-byte the start of the live log, and refuses to follow if not	**Built**	`audit_guard_demo.py`
Hourly verification (`audit_verify`) of both chains and anchors; failures appear in the health panel	**Built**	health panel, docs/40
RFC 3161 timestamp of each anchor from an outside authority (`audit_witness`, when `TSA_URL` is set)	**Built, off by default**; checks status, imprint, nonce, CMS signature, a signer certificate issued directly by a CA **you** supply, validity at the stamped time	25 tests with a local authority; no live authority contacted
Signed ledger (Ed25519 checkpoint over name, row count, head hash and a **Merkle root**)	**Built**	below
Encrypted rows on disk (the chain works on the plain row; the mirror copies the stored bytes, so the second copy is encrypted too; rotation does not rewrite the logs)	**Built**	pen test: every row starts with `enc1:`, and the logs still verify through the API
Concurrent writers do not corrupt the chain	**Built** (file lock, fsync)	race suites

The ledger. The worker signs a checkpoint over each audit log. Anyone with the public key can verify that the history was not rewritten or cut, and can verify a single event with an inclusion proof **without seeing any other event**. `cg ledger ...`, `/api/v1/ledger`, and a card on the audit page. The API holds the public key only; the signing seed is in the worker's environment alone.

What the demonstration shows. `rust/tools/audit_guard_demo.py` edits a past row of the live security log while a server runs. Within seconds the health panel's "Audit log protection" goes from ok to DOWN with "the first 30,931 bytes of the source differ from the mirror" and "Audit chain invalid at event 3", while the mirror still holds the original.

6.3 Traceability for people

- Every finding can be traced from the claim to the rule, the claim paths it rests on, the AI request (with the prompt's hash), the model's reply and every person's decision; the "Audit and traceability" panels and the claim trace show the chain in order.
- A correction is a new version with the old one still visible, so a wrong decision is answered by a new one, never an edit.
- A what-if run stores nothing and changes nothing; only the security log notes that it happened.
- Batch audit samples are recorded with their exact random selection, and the quarantine decision of the administrator is recorded with its general reason.
- An AI explanation says which tier wrote it (`deterministic-template`, or the model and the cascade tier).

6.4 What auditability does not give (stated plainly)

- The log is tamper-**evident** against anyone who cannot rewrite the chain, the anchor and the key together. It is not tamper-proof against someone who controls all three.
- The mirror is immutable only if its volume is (an append-only or object-lock volume). **Retention-locked (WORM) storage and append-only database privileges are not built**; a local file is not immutable and we do not call it that.
- Off-host backups and controlled exports are manual procedures with scripts.
- The audit log keeps the badge numbers of the people who acted (needed for accountability); they are encrypted on disk but visible to anyone with the audit permission.
- The timestamp check is only as good as the CA file the verifier is given; keep it apart from the log writer and choose the authority yourself.

---

7. The AI step and prompt injection

Design rule: the AI never decides. Fifteen deterministic rules decide every verdict. The model adds words to an explanation. It never sets a status, a rule id, a citation or the review flag, and a model failure cannot remove a deterministic finding. A reply that fails any check is replaced by the engine's own sentence.

Layers (each tested in `tests/test_injection_owasp_llm01.py` and the Rust equivalents):

1. **Claim data.** Hostile text in any free-text field, or split across two fields, changes no verdict. Rule-fact forgery (a value that imitates a rule tag) is stopped by percent-encoding claim data before it enters a fact.
2. **The prompt.** Untrusted text is fenced as data, bounded (values cut at 1,000 characters, notes at 4,000, a prompt over 60,000 characters fails closed to the template) and never in the instruction part. A gap found and closed: claim values also reach the prompt through each finding's evidence, above the fence; the prompt now carries an `EVIDENCE_FENCE` before the finding, and tests check that a string planted in six claim fields stays below the label, never reaches the instructions, and that two halves of a payload split across fields are never joined.
3. **The reply.** Schema (citations, rule id and review flag fixed by the finding), approval or payment language, text in another alphabet, garbled text and **invisible characters** (zero-width, bidirectional controls, soft hyphen, variation selectors, tag characters) are rejected. The invisible-character check

rejects no text that was accepted before: of 292,045 recorded strings, 30 contain such a character, all already-rejected gibberish.

4. **Whatever slips through** cannot change the verdict or the review flag.

A real red team found a real weakness. Against the real local gemma3:4b (all 15 of 15 rules produced an accepted template), nine claims whose fields carried instructions and false statements ("IGNORE PREVIOUS INSTRUCTIONS … approved and payable", a fraud accusation, a cancer diagnosis, `<img onerror>`, a fake system prompt, bidirectional and zero-width characters, a 5,000-character value, template braces) went through the whole pipeline. The grounding guard had treated a phrase as "grounded" if it appeared anywhere in the finding, **including the claim's own values and claim id**, so a submitter could plant "this claim is approved and payable" in a service code and have it appear in a reviewer-facing, AI-labelled sentence. Fixed two ways: the guard now counts only fields the engine and the rulebook wrote (an allow-list), and every value is made safe (control, zero-width and direction-changing characters removed, white space collapsed, quotation marks stripped) before it appears in a sentence.

Measured on the explanation experiments (details in `docs/56`, section 9): across all 4,212 live calls no configuration changed a finding (each finding was hashed before and after every call); injection resistance on raw replies reached 100% for the adopted setting on the confirmation cases, and the one known injection variant that obeys a fake delimiter and flips the review flag (VAR-02) is rejected by the schema every time and shows the template.

Still open, recorded as such: approval wording in non-English Latin text (French, Spanish) and in Base64 passes the text guards. It cannot change any status or flag, but a reviewer could read it, which is one reason a person reviews every claim.

Where the AI is *not* used: the reviewer copilot, what-if and correct-and-recheck, the batch audit sample, the requests for information and the fills are all produced by code from the engine's findings, with no model.

---

8. Document intake and the other surfaces added after the first note

Surface	Who may use it	Main threat	Control	Evidence
`POST /api/v1/queue/import/*`	administrators (`routing.manage`), session, CSRF token	a hostile file; an oversized body; a document that talks to the system; a misread identifier	the gate, then the isolated reader (section 5.2); extraction is pattern matching, so text in a document cannot instruct anything; the result is a **draft** that a person compares with the page and confirms; the ordinary submit then validates it again	9 API tests, 18 reader checks, 17 browser checks
The document reader	the server only (bearer token, private network)	rasterizing a hostile PDF; resource exhaustion	one document at a time; page and pixel caps; timeouts; no-new-privileges; all capabilities dropped; the image has 0 high or critical	`ocr_service_test.py`

Surface	Who may use it	Main threat	Control	Evidence
			vulnerabilities with a published fix (Trivy)	
The ledger	read: `audit.view`; sign: the worker only	silent edit or truncation	section 6	8 unit tests, 14 end-to-end checks
The live-update stream	signed-in users with the right permission	leaking data through the stream; connection exhaustion	the stream carries no claim data; per-address and total limits; a revoked session ends it	21 black-box checks
Batch intake (`/api/v1/queue/submit`, asynchronous)	level 4 for polling a job; the submit route has its own body cap (4 MB)	exhausting the server; a poisoned batch	at most 2 batches run at once (a third gets 409), the last 20 finished jobs kept; audit sample and quarantine	`batch_e2e.py`
The embedding sidecar	the API only (bearer token)	leaking data; fetching a model from outside	sees only rulebook passage text and the question; pinned revision; offline; no outbound call	`rag_product_check.py`
The proxy	the internet	unfair traffic; spoofing the client address	TLS 1.2/1.3 and HSTS; header 10 s, body 30 s; body caps per path; the stream unbuffered; `X-Forwarded-For` **overwritten** (not appended) so a client cannot choose its own address and escape the throttle	`nginx_proxy_test.py`, 22 of 22

Safety against invented content in a converted document. A field the reader cannot find stays empty and is listed as missing; an ambiguous date or number is kept as written and blocks acceptance; an identifier not in the catalogue is flagged as a probable misreading, never corrected; where two readers disagree the field is flagged. Of 168 wrong fields in 240 synthetic documents, 167 were flagged and 1 was not.

---

9. How it was tested: methods, results and what each found

9.1 Methods

Method	Tool	What it covers
Black-box penetration test	`rust/tools/pentest.py`	real sockets against a running server: headers, malformed and smuggled HTTP, size limits, slow and many connections, login, sessions, CSRF, every route × every role, object-level access, injection, business logic, resource exhaustion, leakage, dual control, encrypted logs
Fuzzing	`crates/cg-api/tests/api_fuzz.rs`	random method, path, query, headers and body (binary, control and bidirectional characters, injection-style JSON keys) with sessions of each role; seeded, so a failure replays

Method	Tool	What it covers
Mutation test	`rust/tools/mutate.py`	breaks a security rule on purpose and checks that a test fails
Deployment attack	`rust/tools/deploy_attack.py`	the Compose stack brought up with throw-away secrets and attacked
Real-model red team	`cg model-check`, `rust/tools/model_redteam.py`	gemma3:4b through the whole pipeline
Load and exhaustion	`rust/tools/flood.py`	one machine, one address
Browser attack	`xss_seed.py`, `xss_browser.py`	real Chrome
Side channel	`cargo test -p cg-access --test timing`	refusal timing
Backup and restore	`backup_restore_test.py`	destroy every volume, restore
Static and dependency scans	`bandit`, `pip-audit`, `cargo audit`, `detect-secrets`, Trivy	code and supply chain

9.2 Penetration test: 116 checks, all pass

Area	Checks	What was tried
Headers, CORS, methods	13	version banner, security headers, an `Origin` of another site, TRACE/CONNECT/unknown verb
Request smuggling and malformed input	10	two lengths, length with chunking, NUL, folding, HTTP/1.0, garbage, no Host, 100,000-level nested JSON, duplicate keys, invalid UTF-8
Size limits and slow connections	8	70 KB header and request line, 80 KB body, 300 half-open connections while another client is served, a flood of password hashes
Authentication and sessions	8	timing, identical answers, code reuse, cookie flags, throttle with rotated `X-Forwarded-For` / `X-Real-IP` / `Forwarded`, forged tokens (none, weak keys, swapped payload, truncated)
CSRF and cross-site	4+	no token, another user's token, form-encoded and plain-text cross-site posts
Authorization	11	every role against 12 reads and 3 writes; administrator reading or deciding claims; mass assignment; self-promotion; deciding or verifying another reviewer's claim
Injection and path traversal	16	NoSQL operators and arrays in login fields, claim ids with traversal / `%00` / `$ne`, `/ui/../`, `..%2f`, `%2e%2e`
Business logic	9	six malformed decision bodies, countersigning one's own decision, eight parallel configuration updates (one winner, seven 409s)
Information leakage	4	error bodies for framework, path and library names; raw identifiers in a claim view; hashes and seeds in the user list
Third-round and dual control	33	cross-site refusal, identifier-free reasons, unmask rationing, approvals end to end, encrypted logs on disk and still verifiable

Two real faults found and fixed by the first run: connections held open forever (now a 10-second header limit, a 16 KB header block cap, 2,048 connections and a 5-minute lifetime) and a 70 KB header accepted.

9.3 Fuzzing and mutation

- **Fuzzing: 400,000 random requests, 0 server errors, 0 leaks.**

- **Mutation: 75 deliberate breakages of the security rules in the full run, all caught** (the harness grew to 93 with the broker's 18). Along the way: 8 of the first 36 were missed until tests were added; one third-round mutant survived until its test was tightened; two older mutants had gone stale and were repaired; six database mutants looked alive only because their tests skip without a real MongoDB, so the harness must be run with one.

9.4 Deployment attack: 50 checks, found four real problems

The stack was brought up and attacked: TLS 1.0 and 1.1 refused, TLS 1.3 with HTTP/2 accepted, forward-secret ciphers, HSTS, no banner, port 80 only redirects; a 20 KB header, a 1 MB body and 60 half-sent requests against the proxy; only the proxy publishes a port; the proxy cannot reach MongoDB or Redis; they have no route out and refuse missing or wrong passwords; the container hardening of section 5.2; the image holds no secret, key or demo file. **Found and fixed:**

1. the audit-mirror volume would have been root-owned, so the unprivileged worker could not have written it;
2. a 1 MB request through the proxy ended as a 502 instead of a clean 413 (the proxy now caps bodies at 100 KB itself);
3. the database and cache shared a network with the proxy (now an `internal` network with no route out) and Redis had no password (now it demands one);
4. the Debian image carried 241 findings (4 critical, 54 high), nearly all in operating-system tools the program never uses; the runtime image is now distroless: **49 findings, none critical, one high** in a library that is present but not loaded (the program uses rustls).

9.5 The rest

Test	Result
Real-model red team (gemma3:4b)	15 of 15 templates accepted; **one real guard weakness found and fixed** (section 7)
Load and exhaustion, one machine	3,000 idle connections; 300 clients for 20 s (29,700 requests, all 200); 200 clients without a session (18,799 requests, all 401); a 400-client sign-in flood (341 ordinary refusals then 429s, no 5xx); 100 clients sending 60 KB bodies. A polite client was answered in 1 to 12 ms throughout; memory never passed 87 MB
Console in a real browser	19 checks; payloads in 10+ fields; no script ran, no inline handler, iframe, foreign stylesheet or `javascript:` address existed; the payload text was visible as plain text
Refusal timing	all eight kinds of refusal within 3% (80.3 to 82.6 ms)
Backup and restore	23 checks: put in users and 12 claims; back up; the file shows no readable claim id, badge number or JSON; destroy every volume; start empty and confirm nobody can sign in; a wrong key and a damaged file refused; restore. **Found two real bugs in its own first version** (a whole-server dump replaced the database's own users in the middle of the restore; the first script reported success even when the restore failed)
nginx in front	22 of 22; found and fixed a real fault
Batch intake	1,000 claims accepted in 0.06 s (request) and about 17.5 s (batch); a level 3 user cannot read the job (403); an unknown job is 404
Broker	a forged message changes nothing; poison input dead-letters after three tries; credentials never appear in an error text; an independent read-only review found five issues, all fixed with tests

Test	Result
Arabic intake	refusals of Hijri and ambiguous dates, unknown fields, duplicate fields and hidden characters in identifiers; 8 of 8 end to end
Python-era audit (OWASP Top 10 for LLM applications and OWASP Top 10, `docs/20`)	fixed: rule-fact injection, unbounded prompt size, log forging, a forgeable audit anchor, silent replays (a resubmitted claim id is now logged and routed to a human even if clean), defects outside the 15 rules (advisory events); 0 high from `bandit`

9.6 Dependencies and supply chain

- `pip-audit` on every requirements file in the repository: clean after the 2026-10-06 bumps (before: torch 22, transformers 28, Pillow 33, langchain-core 11 and others in two files that only reproduce frozen experiments).
- `cargo audit` on 439 crates: **five advisories, all reached only through `yara-x`** (an embedded WebAssembly engine; `wasmtime` four advisories, `rsa` Marvin timing attack on private-key operations of which ClaimGuard has none), one unmaintained crate (`bincode`). Each was looked at and recorded with its reason in `rust/.cargo/audit.toml`; the audit exits 0 and any new advisory fails it.
- Every third-party image pinned by digest; the installer generates a separate `DATA_KEY`; the first administrator is created from standard input, never an argument.
- Trivy on the reader image: 0 high or critical vulnerabilities with a published fix.

---

10. Operations and resilience

- **Runbook** (`docs/40`): install, every setting, what each secret protects and what happens if it is lost or changed, backup and restore, key rotation, updates, the health panel component by component, incident playbooks (audit alarm, locked user, stolen session, data seen by someone who should not have), and the exact order of checks to run on the target machine.
- **Key rotation:** `cg rotate-key` re-encrypts every claim, result, explanation, decision and name from the old data key to the new one (it stops rather than damage a document, skips what changed meanwhile, and can be repeated); `cg rotate-fernet-key` re-encrypts every authenticator seed so nobody re-enrols. Rotation does not rewrite the logs (that would break the chain, the mirror and every timestamp): new rows use the new key and the old secret stays in `DATA_KEY_PREVIOUS`.
- **Health panel:** the audit protection, the queue, the worker, the disk and the ledger report ok / down; a failed verification, a diverged mirror or a full disk is visible.
- **Host firewall:** `deploy/rust/firewall.sh` and an outside port check, tested in containers.
- **Reproducible images:** digests pinned; security updates are taken deliberately (procedure in `docs/40`).

---

11. Why the language matters for security

The decision to rebuild in Rust (`docs/36`, taken 2026-10-09) was driven by memory, safety and speed of the parts that run without a model. Rust has no null, checks ownership and data races at compile time and forces exhaustive matching. On the robustness probe, a `null` where a struct is expected is a parse error, and the Rust

server returned a clean 400 in all cases. The judged bug-resistance score (a judgement, with reasons written down) was Rust 9, C# 7, Go 6, Java 6, TypeScript 5, Python 4 out of 10; the language benchmark is in `docs/56`.

---

12. Known gaps, and what a real deployment would still need

1. **Not run on the target server** (RTX 3080, Linux): the host firewall, the machine's own hardening, its Docker daemon and a certificate from a public authority are untested. `docs/40` section 9 is the checklist for that day.
2. **No outside party has tested it.** The penetration test, the fuzzing and the red team were written and run by us.
3. **Subject access and erasure are not built.** Designed: erasure by destroying the keyed index entry and the claim's sealed fields for that person; export of everything held about one person. Must be built and tested before a real deployment.
4. **Retention is not built** beyond short-lived data that expires by itself. The insurer must decide how long claims and logs are kept.
5. **The logs are tamper-evident, not immutable:** WORM storage, an INSERT-only database role and off-host backups are not built; a live timestamp authority was never contacted.
6. **Two-person rules cannot know that two accounts belong to two people**; a lone administrator acts alone (and is logged).
7. **User records other than the name** (level, permissions, timestamps) are readable in the database; disk or volume encryption is still advised underneath. Key custody (who holds `.env`) is an organisational control.
8. **A distributed denial of service, floods below the HTTP layer and exhaustion of the database server** are untested; a burst of parallel sign-ins can pass the throttle check before the counts catch up (bounded by concurrency, not by time).
9. **An attacker with the Redis port can fill the stream** (harmless to claims, each message being checked against the stored hash).
10. **AI step:** non-English Latin text and Base64 pass the text guards; misleading-but-schema-valid wording is possible; the extra evidence-fence sentence changed the prompt's hash, and its effect on answer quality was not re-measured against the frozen experiments.
11. **Documents:** hidden text inside a PDF's text layer is read like visible text; real hospital paper, handwriting, stamps and Arabic documents are untested; the reader image's Arabic OCR data is not included.
12. **Arabic intake:** every label, month name and phrase was written by the assistant and has not been reviewed by a native speaker; a wrong entry can produce a refusal or a field mapped to the wrong English name, but cannot change an amount or an identifier.
13. **The batch job table lives in memory;** a restart forgets running jobs (sending the batch again is the repair); two API copies behind a load balancer are untested.
14. **The desktop app is unsigned,** Windows only, and was not run on a clean PC. The Docker image of the embedding sidecar was not rebuilt for the new model (the script runs it on the GPU or CPU).
15. **Notification of a breach** to the authority and the people affected is a process, not software; the runbook says what to collect.
16. **No formal data-protection impact assessment, no named data-protection officer,** no single-sign-on or password-reset story, and no signed data-processing agreement: these belong to the

organisation that runs the system.

17. **The build machine's own disk is almost full** and the health panel reports `disk: down`, correctly: a finding about this laptop, not the product.

---

13. Reproduce everything and where it lives

```
cd rust && cargo test                                  # 300+ tests; database tests need MONGO_URI and RED
python rust/tools/pentest.py                           # 116-check black-box penetration test
cargo test -p cg-api --test api_fuzz                   # 400,000 fuzzed requests
python rust/tools/mutate.py                            # mutation test (needs a real MongoDB and Redis)
python rust/tools/deploy_attack.py                     # 50 checks on the Compose stack
python rust/tools/model_redteam.py                     # real-model red team
python rust/tools/flood.py                             # 16 load checks
python rust/tools/xss_seed.py && python rust/tools/xss_browser.py   # 19 checks in Chrome
cargo test -p cg-access --test timing -- --ignored     # refusal timing
python rust/tools/backup_restore_test.py               # 23 checks
python rust/tools/nginx_proxy_test.py                  # 22 checks
python rust/tools/audit_guard_demo.py                  # edits a log row and watches the alarm
python rust/tools/arabic_e2e.py && python rust/tools/batch_e2e.py
cargo audit; pip-audit -r requirements.txt             # dependency scans
python scripts/verify_audit.py --log <log> --require-key   # Python-era audit verification
```

Topic	Document
Python-era privacy and security note (sections 1 to 9)	`docs/32`
OWASP audit and red team of the Python build	`docs/20`
Audit log design	`docs/16`
Security results of the Rust build (four rounds, the broker)	`docs/39`
Data protection against Middle East laws	`docs/41`
Operations runbook, key rotation, backup, incident playbooks	`docs/40`
Ledger, document intake, payer rules, live updates	`docs/45`, `docs/44`
Batches, audit sample, quarantine	`docs/53`
nginx and traffic handling	`docs/54`
Deployment handover	`docs/47`
Language choice and its robustness probe	`docs/36`
Tests, detection metrics and experiments (the other submission)	`docs/56`